

ARMP Changelog — ARMP-2026.07.21-PILOT-AUTH-R3

Fresh release. Supersedes R2 (ARMP-2026.07.21-P1P2-R2). Do not deploy R2 for real-data pilots.

Added — server-controlled pilot access

- Supabase Auth (email/password + mandatory TOTP MFA / AAL2), invitation-only (public signup disabled).
- 12 PostgreSQL migrations: organizations, profiles, memberships, internal roles, pilot entitlements, invitations, security/activation events, admin-action requests; state-transition + seat-limit triggers; `authorize_pilot_session()`.
- Row-Level Security: default-deny on every protected table; org isolation; internal-notes column protection; no `using(true) / with check(true)` on protected tables.
- 20 Edge Functions for all privileged actions (service-role isolated to the function environment).
- Five `/auth/` pages: invite, callback, setup-mfa (QR + manual key), challenge-mfa, reset-password.
- `app.html` server-authorization gate: decision before real-data workflow, ≤ 300 s revalidation, no Demo fallback on failure, R2-`localStorage` cannot authorize.
- `admin.html` Operations Console: Supabase session + AAL2 + internal-role gate (Google domain check removed); Organizations/Users/Invitations/Activity views.

Removed

- R2 format-only pilot code, `isValidPilotCode`, the license inputs, and client-side pilot-plan grant.
- Google email-domain console gate.

Tests

- Retained the **503 R2 assertions unweakened**.
- Added: frontend-security (Suite 10), network-instrumented data-boundary (Suite 11), R2-migration (Suite 12); expanded prohibited-pattern gate (Suite 9, R3, context-aware).
- Local proofs: RLS 26/26 on real Postgres; Edge Functions type-check under Deno.

Not built / not validated

Staging deployment and the 16-step E2E are NOT YET RUN. Paid production remains blocked.